Active Reconnaissance & Vulnerability Assessment Report

Objective

To perform active reconnaissance and vulnerability scanning on a controlled lab environment (Metasploitable VM) using Nmap and Nikto, and to identify security weaknesses.

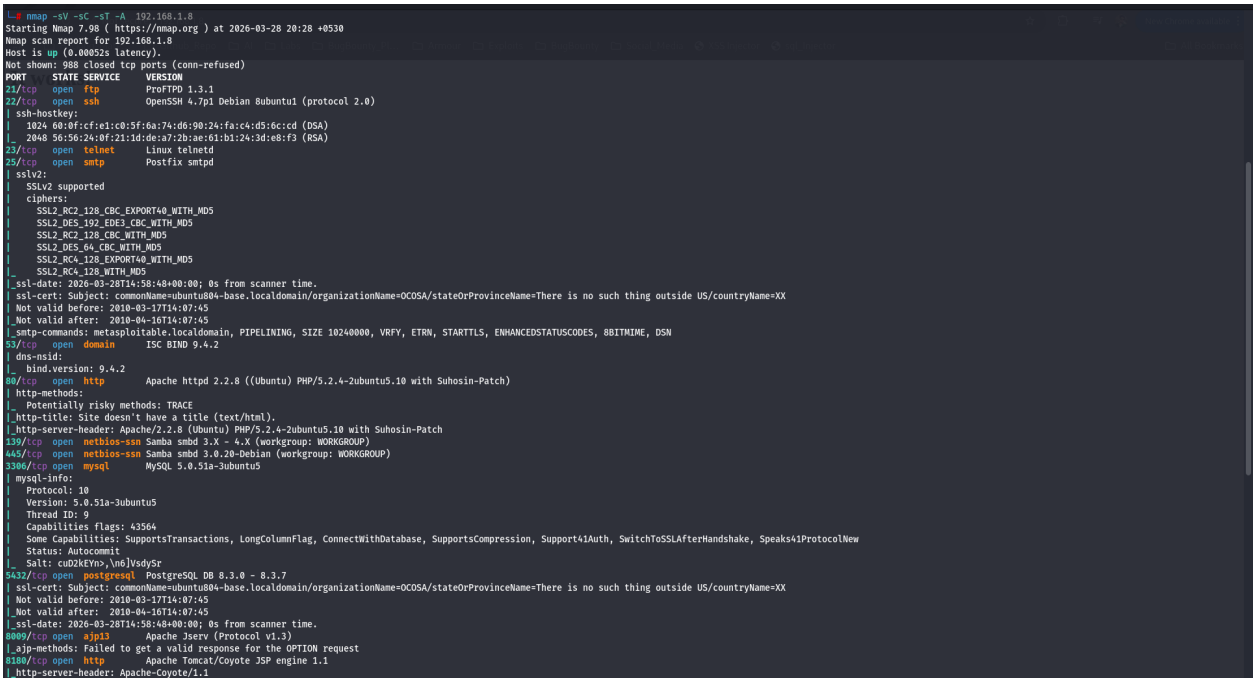
Target Information

Parameter	Details
Target IP	192.168.1.8
Hostname	metasploitable.localdomain
OS	Linux 2.6.x
Environment	Virtual Lab (Safe)
Scan Date	28 March 2026
Tools Used	Nmap, Nikto

1. Port & Service Enumeration

Tool: Nmap

Command: nmap -sV -sC -sT -A 192.168.1.8



```
└─# nmap -sV -sC -sT -A  192.168.1.8
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-28 20:28 +0530
Nmap scan report for 192.168.1.8
Host is up (0.00052s latency).
Not shown: 988 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         ProFTPD 1.3.1
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|_    SSL2_RC4_128_WITH_MD5
|_ssl-date: 2026-03-28T14:58:48+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) PHP/5.2.4-2ubuntu5.10 with Suhosin-Patch)
| http-methods:
|_  Potentially risky methods: TRACE
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.10 with Suhosin-Patch
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 9
|   Capabilities flags: 43564
|   Some Capabilities: SupportsTransactions, LongColumnFlag, ConnectWithDatabase, SupportsCompression, Support41Auth, SwitchToSSLAfterHandshake, Speaks41ProtocolNew
|   Status: Autocommit
|_  Salt: cuD2kEYn>,\n6]Vsdy5r
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-03-28T14:58:48+00:00; 0s from scanner time.
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
```

Figure 1: Nmap Scan Output

Key Findings

Port	Service	Version
21	FTP	ProFTPD 1.3.1
22	SSH	OpenSSH 4.7p1
23	Telnet	Linux telnetd

25	SMTP	Postfix smtpd
53	DNS	BIND 9.4.2
80	HTTP	Apache 2.2.8
139/445	SMB	Samba 3.x
3306	MySQL	MySQL 5.0.51
5432	PostgreSQL	PostgreSQL 8.3
8180	HTTP	Apache Tomcat

2. Web Vulnerability Scan

Tool: Nikto

Command: nikto -h http://192.168.1.8

```
8180/tcp open  http       Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
MAC Address: 08:00:27:92:88:BF (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Host:  metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-03-28T10:58:39-04:00
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: 59m59s, deviation: 2h00m00s, median: 0s
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

TRACEROUTE
HOP RTT     ADDRESS
1   0.52 ms 192.168.1.8

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.96 seconds
```

Figure 2: Nikto Scan Output

```
┌──(root㉿kali)-[/home/kali]
└─# nikto -url 192.168.1.8
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.1.8
+ Target Hostname:    192.168.1.8
+ Target Port:        80
+ Start Time:         2026-03-28 20:31:02 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.10 with Suhosin-Patch
+ /: Server may leak inodes via ETags, header found with file /, inode: 67575, size: 45, mtime: Wed Mar 17 19:38:25 2010. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missi
g-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,htt
s://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.1.5), PHP 7.4.28 for the 7.4 branch.
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE .
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ PHP/5.2 - PHP 3/4/5 and 7.0 are End of Life products without support.
+ /phpinfo.php?VARIABLE=<script>alert('Vulnerable')</script>: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /tikiwiki/tiki-graph_formula.php?w=1&h=1&s=1&min=1&max=2&f[]=x.tan.phpinfo()&t=png&title=http://blog.cirt.net/rfiinc.txt: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookie
+ /tikiwiki/tiki-graph_formula.php: Output from the phpinfo() function was found.
+ /tikiwiki/tiki-graph_formula.php?w=1&h=1&s=1&min=1&max=2&f[]=x.tan.phpinfo()&t=png&title=http://blog.cirt.net/rfiinc.txt: TikiWiki contains a vulnerability which allows remote attackers to execute arbitrary PHP code. See: http://cve.mi
re.org/cgi-bin/cvename.cgi?name=CVE-2007-5423
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8909 requests: 1 error(s) and 19 item(s) reported on remote host
+ End Time:           2026-03-28 20:31:33 (GMT5.5) (31 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Figure 3: Nikto Scan Output

Key Findings

- Outdated Apache (2.2.8) and PHP (5.2.4)
- Missing security headers (X-Frame-Options, X-Content-Type)
- Directory indexing enabled
- HTTP TRACE method enabled
- phpinfo() exposed
- TikiWiki Remote Code Execution vulnerability
- Configuration file exposure (wp-config.php)

Risk Summary

Severity	Count
High	3
Medium	4
Low	3+

Recommendations

- Disable Telnet and use SSH
- Close unnecessary ports and apply firewall rules
- Upgrade Apache and PHP to supported versions
- Disable directory indexing and remove phpinfo()
- Disable HTTP TRACE method
- Restrict database access and use strong credentials
- Enable SMB signing and patch outdated services

Conclusion

The Metasploitable system exposes multiple critical vulnerabilities due to outdated software and insecure configurations. These findings demonstrate a high-risk environment and highlight the importance of proper system hardening and patch management.